

互联网+环境下的信息安全 风险与认证



中国信息安全认证中心
CHINA INFORMATION SECURITY
CERTIFICATION CENTER

宋 扬

2015年9月

内 容 提 纲

一、我国的认证认可体系

二、国外信息安全认证发展情况

三、我国信息安全认证认可工作进展

一、我国的认证认可体系

1、认证认可制度的起源和发展

20世纪初，工业化国家在大规模生产的情况下，为了提高交易效率，建立买卖双方的互相信任，而引入公正的第三方，用科学的方法对商品进行评价的活动，逐渐演化形成认证制度。

20世纪90年代以来，国际上陆续建立了相应的国际组织和国际互认制度，并由此推动认证认可活动进入国际化发展阶段，成为国际公认的质量基础设施。

一、我国的认证认可体系

1、认证认可制度的起源和发展（续）

20世纪80年代以来，我国各类产品认证、体系认证以及认可工作随着我国经济不断融入国际经济体系之中而不断完善发展。

1981年4月，我国建立了第一个产品认证机构，中国电子元器件认证委员会，建立了产品认证制度。

1993年，《中华人民共和国产品质量法》首次颁布，明确质量认证制度为国家的基本质量监督制度。

2003年，《中华人民共和国认证认可条例》发布，我国建立起统一的认证认可监督管理制度。

一、我国的认证认可体系

1、认证认可制度的起源和发展（续）

随着我国经济社会发展水平和对外开放程度的不断提升，认证认可的地位和作用越来越重要。

截至2014年底，我国已有各类认证机构195家，累计颁发各类认证证书130余万张，获证组织达40余万家。

一、我国的认证认可体系

2、认证认可的基本概念

合格评定：证实与产品、过程、体系、人员或机构有关的规定要求得到满足。

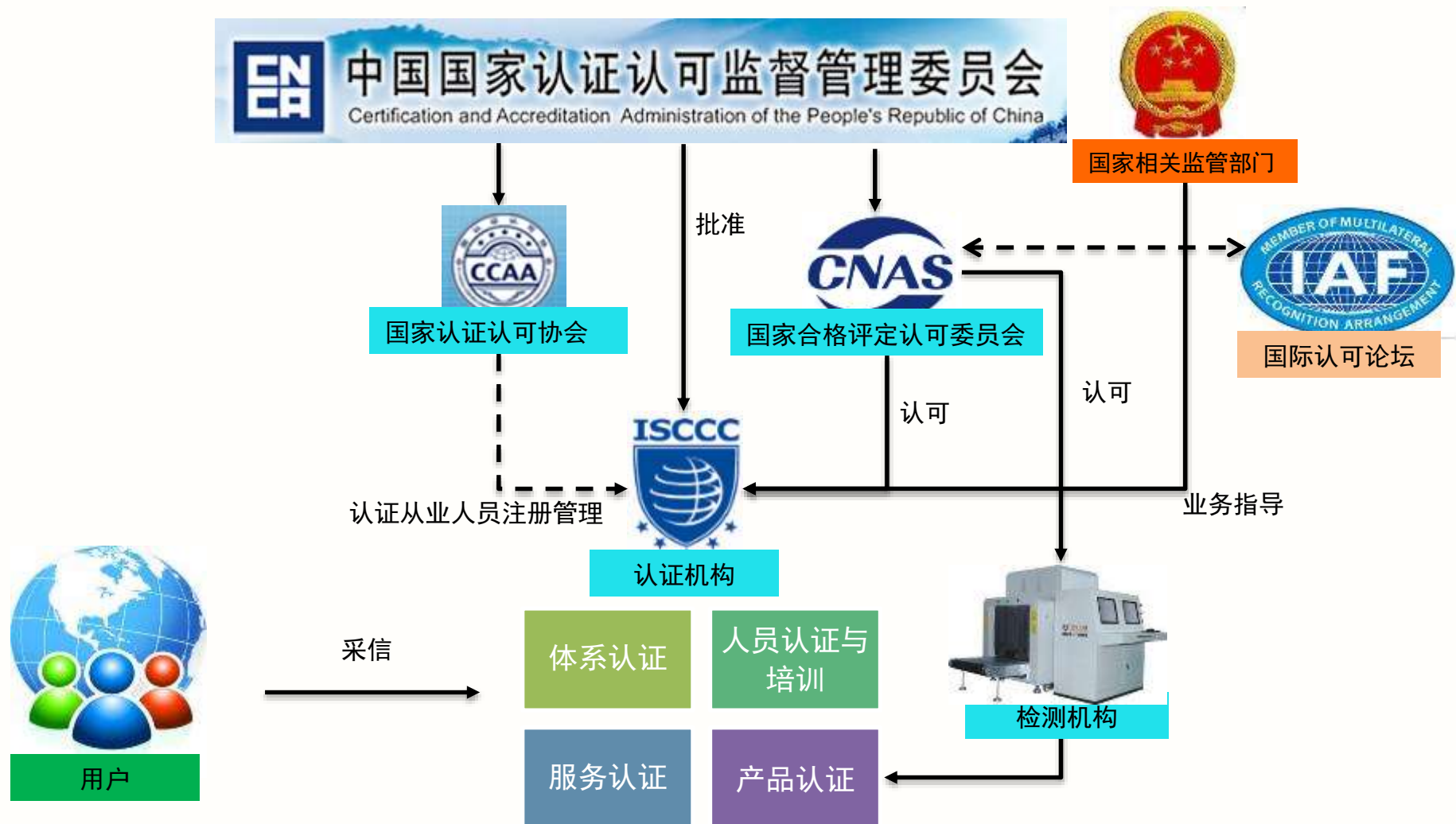
合格评定的专业领域包括检测、检查和认证，以及对合格评定机构的认可活动。

合格评定对象包括接受合格评定的特定材料、产品、安装、过程、体系、人员或机构。其中产品包括服务。

来源：国家标准GB/T 27000《合格评定 词汇和通用原则》（等同采用国际标准ISO/IEC 17000）、GB/T 27011《合格评定 认可机构通用要求》（等同采用国际标准ISO/IEC 17011）、国家认证认可条例。（下同）

一、我国的认证认可体系

3、我国的认证认可体系



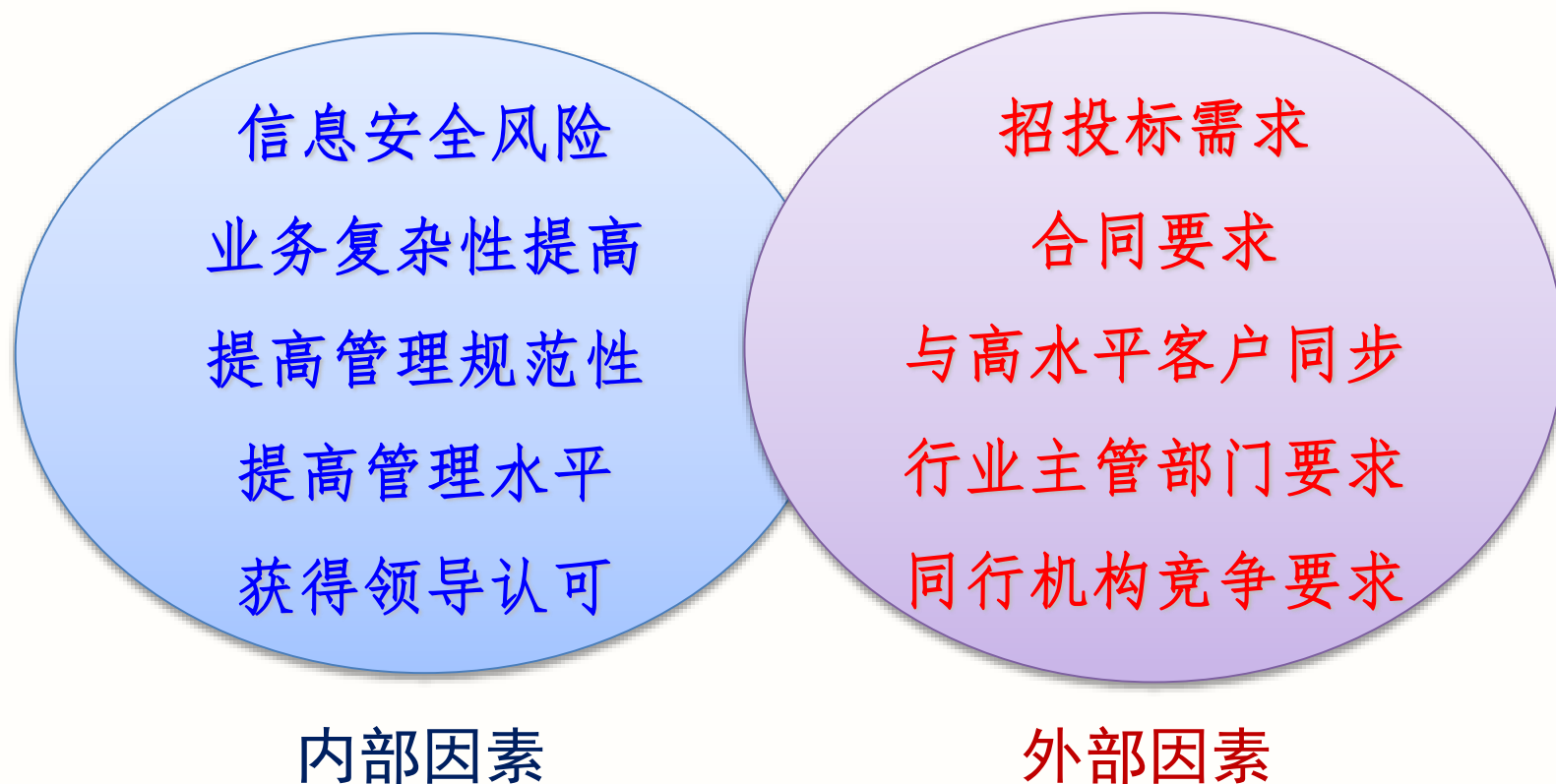
一、我国的认证认可体系

5、为什么要进行认证？

- ISO9001，解决组织在达到一定规模后，制约发展的流程规范性方面的问题；
- ISO20000，解决组织在信息化建设达到一定水平，信息技术在持续高效支撑业务发展方面的问题；
- ISO27001，解决组织在信息化水平提高的过程中，所带来的信息安全管理问题。

一、我国的认证认可体系

5、为什么要进行认证？



内 容 提 纲

一、我国的认证认可体系

二、国外信息安全认证发展情况

三、我国信息安全认证认可工作进展

二、国外信息安全认证发展情况

1、国外信息安全产品认证情况

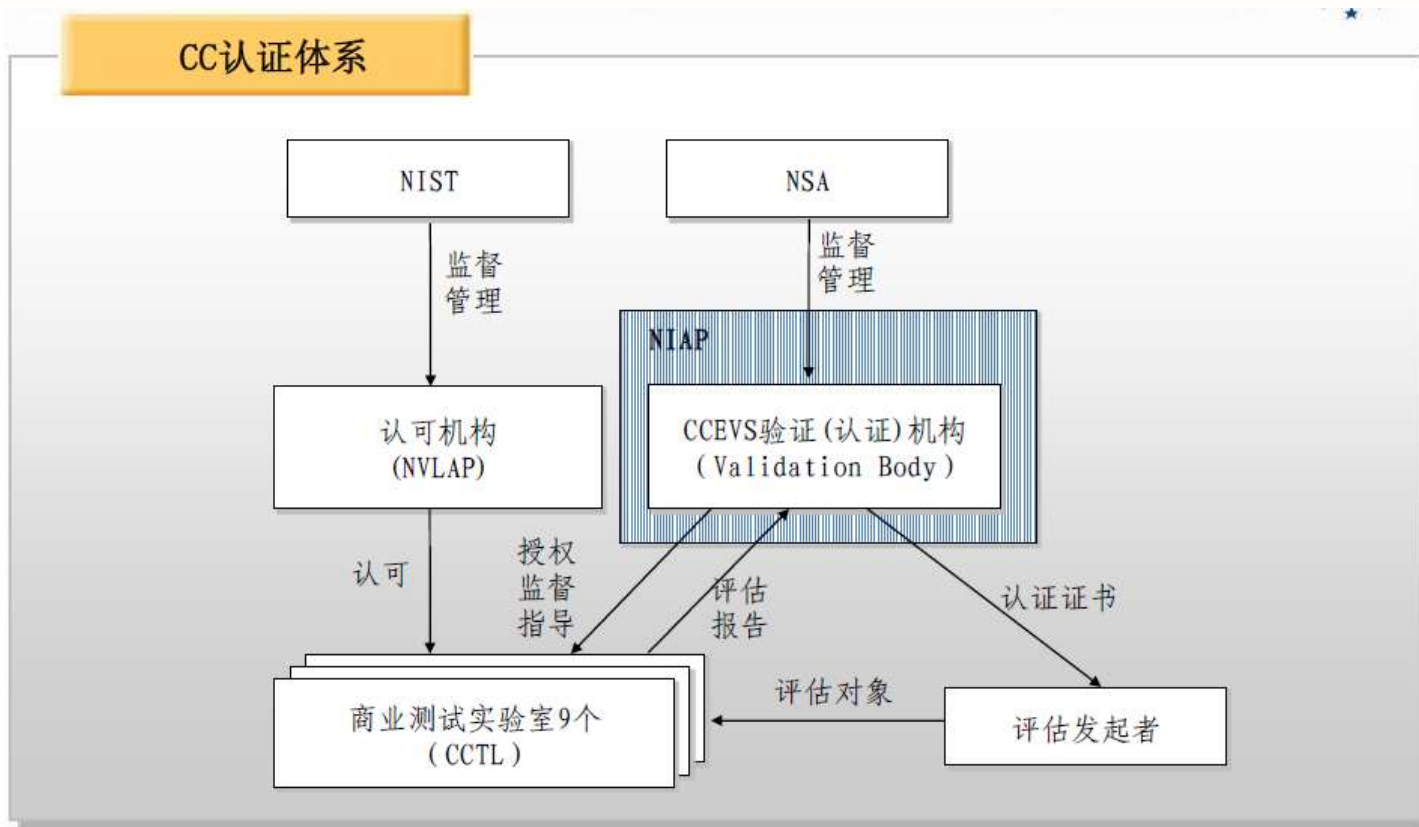
➤ 美国

为落实信息安全政策、法律，美国将政策执行、监督、管理权分批给多个部门，其中与IT产品信息安全审查、管理最为密切的部门为国家标准技术研究院（NIST）和国家安全局（NSA）。1997年，NIST和NSA联合建立国家信息保障联盟（NIAP），在国家安全系统中强制使用经过NIAP评估的产品。

二、国外信息安全认证发展情况

1、国外信息安全产品认证情况

➤ 美国



二、国外信息安全认证发展情况

1、国外信息安全产品认证情况

➤ 德国

德国的信息安全评估和认证由国家信息安全局（BSI）全权负责。与其他欧盟国家类似，德国对IT产品的信息安全管理主要通过CC认证和TR认证实现。欧盟国家积极参与开发和维护保护轮廓（PP）和技术指南（TR），并依据认可制度评定检测实验室的资格。

基于TR的认证尤其适用于应用于联邦政府部门安全敏感领域的IT产品或系统。

二、国外信息安全认证发展情况

1、国外信息安全产品认证情况

➤ CC认证实施情况（截至2014年底）

2101 Certified Products by Category *		
Category	Products	Archived
Access Control Devices and Systems	87	20
Biometric Systems and Devices	3	0
Boundary Protection Devices and Systems	126	55
Data Protection	83	21
Databases	45	29
Detection Devices and Systems	43	15
ICs, Smart Cards and Smart Card-Related Devices and Systems	801	13
Key Management Systems	36	10
Multi-Function Devices	226	87
Network and Network-Related Devices and Systems	225	40
Operating Systems	106	37
Other Devices and Systems	235	78
Products for Digital Signatures	81	4
Trusted Computing	4	0
Totals:	2101	409
Grand Total:		2510

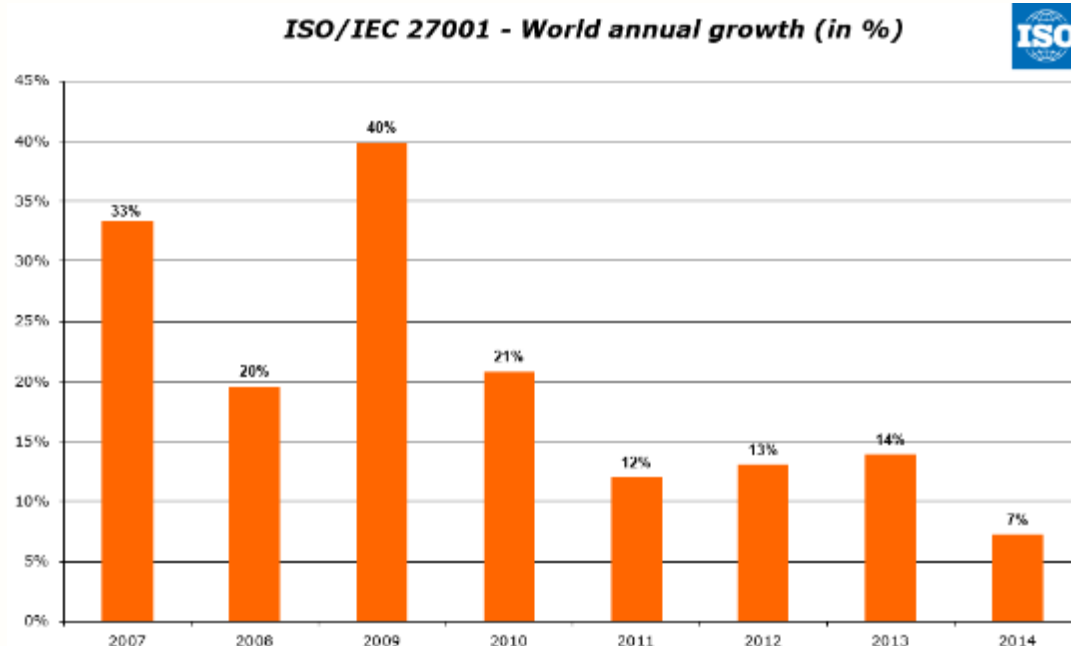
** A Certified Product may have multiple Categories associated with it.*

二、国外信息安全认证发展情况

2、国外信息安全管理体系认证情况

➤ 根据ISO Survey相关数据，截至2014年底，全球已颁发ISO27001信息安全管理体系认证证书23972张。

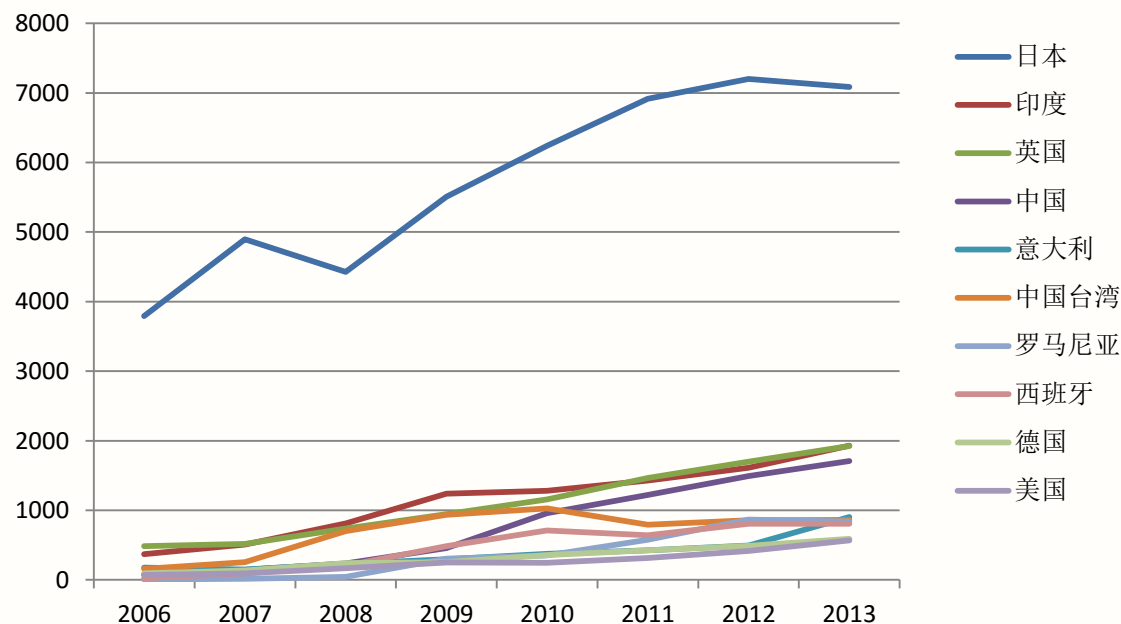
➤ 自2011年开始，ISMS颁证数量已进入平稳增长期。2014年的增长速度降为7%。



二、国外信息安全认证发展情况

2、国外信息安全管理体系认证情况

- ISMS证书数量排名前十名的国家和地区（见下图）
- 2006年至2013年整体呈现增长趋势，其中日本在证书数量和增长速度均表现出绝对的领先地位，英国、印度和中国处于第二阵营。



二、国外信息安全认证发展情况

3、国外信息安全服务审查认证情况

据调查，国外对服务的审查认证主要集中在云计算、身份鉴别和通信等服务领域。特别是对为政府部门、重要基础设施服务的提供商，有较为严格的审查认证要求。

下面以云服务为例，简要介绍美国、英国的做法。

二、国外信息安全认证发展情况

4、国外信息安全人员认证情况

人员认证认可作为一种国际通行的认证认可制度，得到大多数国家的认可和采信。大量认证机构获得以ISO/IEC17024为标准的认可，并得到国际互认。其中：

美国、英国、德国获得人员认证认可的机构分别达到49家、23家、63家。人员认证的范围不仅涵盖了认证认可从业人员（审核员、评审员、检查员），还涵盖了信息技术、医疗、化工、消防等不同行业的专业人员。

二、国外信息安全认证发展情况

4、国外信息安全人员认证情况

美国获得认可的IT人员认证类别：

Cisco Systems

CCNA (Cisco Certified Network Associate) Route and Switch
CCNP (Cisco Certified Network Professional) Route and Switch
Cisco Certified Network Associate Security (CCNA Security)
Cisco Certified Network Professional Security (CCNP Security)

Computing Technology Industry Association (CompTIA)

CompTIA A+ ce
CompTIA Advanced Security Practitioner (CASP)
CompTIA Network+ ce
CompTIA Security+ ce

International Information Systems Security Certification Consortium, Inc. (ISC)2

Certification and Accreditation Professional (CAP)
Certified Information Systems Security Professional (CISSP)
Certified Secure Software Lifecycle Professional (CSSLP)
Information Systems Security Architecture Professional (ISSAP)
Information Systems Security Engineering Professional (ISSEP)
Information Systems Security Management Professional (ISSMP)
Systems Security Certified Practitioner (SSCP)

Global Information Assurance Certification (GIAC)

GIAC Certified Enterprise Defender (GCED)
GIAC Certified Forensic Examiner (GCFE)
GIAC Certified Forensics Analyst (GCFA)
GIAC Certified Incident Handler (GCIH)
GIAC Certified Intrusion Analyst (GCIA)
GIAC Global Industrial Cyber Security Professional (GICSP)
GIAC Mobile Device Security Analyst (GMOB)
GIAC Penetration Tester (GPEN)
GIAC Security Essentials Certified (GSEC)
GIAC Security Leadership Certification (GSLC)
GIAC Systems and Network Auditor (GSNA)

Information Systems Audit and Control Association

Certified In Risk and Information Systems Control (CRISC)
Certified in the Governance of Enterprise IT (CGEIT)
Certified Information Security Manager (CISM)
Certified Information Systems Auditor (CISA)

Cisco和ISC²所开展的人员认证在我国有较大影响。

二、国外信息安全认证发展情况

4、国外信息安全人员认证情况

2011年9月，美国土安全部和人力资源办公室牵头提出《网络安全人才队伍框架（草案）》，明确了网络安全专业领域、岗位人员应具备的“知识、技能、能力”；2012年美国发布《网络安全教育战略计划》（NICE），明确提出了对普通公众、在校学生、网络安全专业人员三类群体进行教育和培训，以提高全民网络安全风险意识、扩充网络安全人才储备、培养具有全球竞争力的网络安全专业队伍。

二、国外信息安全认证发展情况

4、国外信息安全人员认证情况

2013年，美国发布了网络空间安全人才队伍建设框架。该框架将网络安全从业人员分为7大类，31个专业领域。并对31个专业领域及相关岗位的职责、知识、技能、能力进行了明确定义。



二、国外信息安全认证发展情况

4、国外信息安全人员认证情况

英国在2009年发布《网络安全战略》中强调：通过建立认证培训方案，提升从事信息保障和网络安全专业人员的技能水平；加强研究生教育，扩展具有深度网络知识的专家库。同时，英国政府还加强了高校硕士专业认证，以提升对网络安全专家的培养力度。

日本在2011年发布《保护国民网络安全》文件，采用通用人才评估和教育工具、大学与产业合作开发的实用型培养方法等来培养网络安全专家，并为这些专家规划可行的职业道路。

内 容 提 纲

一、我国的认证认可体系

二、国外信息安全认证发展情况

三、我国信息安全认证认可工作进展

三、我国信息安全认证工作进展

1、我国信息安全认证认可制度与体系

- 2003年，《国家信息化领导小组关于加强信息安全保障工作的意见》（中办发27号文）要求“规范和加强信息安全产品测评认证工作”。
- 2004年，原国信办、质检总局、认监委、公安部等8部委《关于建立国家信息安全产品认证认可体系的通知》（国认证联57号），要求建立统一的信息安全产品认证认可体系。
- 2006年6月，中编办批复设立中国信息安全认证中心。国家质检总局直属事业单位。

三、我国信息安全认证工作进展

1、我国信息安全认证认可制度与体系

- 《国家“十二五”规划》和《国家质量发展纲要》中明确要求“完善信息安全认证认可体系”。
- 近年来，中央和国务院有关领导多次就信息安全认证检测工作进行批示，要求加快标准认证体系建设。
- 中央网信领导小组成立后，明确要求加快完善网络安全产品认证制度。
- 2013年，质检总局批准信安中心建设7个分中心。
- 2014年，国家信息安全产品质量监督检验中心正式成立。

三、我国信息安全认证工作进展

2、我国信息安全认证认可制度与体系——产品认证

- 2008年1月，质检总局和认监委发布了《关于部分信息安全产品实施强制性认证的公告》（2008年第7号），宣布自2009年5月1日起，对部分信息安全产品实施强制性认证。
- 2009年4月27日，按照国务院领导的批示精神，质检总局、财政部和认监委联合发布了《关于调整信息安全产品强制性认证实施要求的公告》（2009年第33号），宣布将信息安全产品认证的实施时间延至2010年5月1日，在政府采购法规定的范围内强制实施。

三、我国信息安全认证工作进展

2、我国信息安全认证认可制度与体系——产品认证

➤ 国家信息安全产品认证目录（8类13种）

大类	小类
1、边界安全	1) 防火墙
	2) 网络安全隔离卡与线路选择器
	3) 安全隔离与信息交换产品
2、通信安全	4) 安全路由器
3、身份鉴别与访问控制	5) 智能卡COS
4、数据安全	6) 数据备份与恢复产品
5、基础平台	7) 安全操作系统
	8) 安全数据库系统
6、内容安全	9) 反垃圾邮件产品
7、评估审计与监控	10) 入侵检测系统（IDS）
	11) 网络脆弱性扫描产品
	12) 安全审计产品
8、应用安全	13) 网站恢复产品

三、我国信息安全认证工作进展

2、我国信息安全认证认可制度与体系——管理体系认证

- 2010年8月12日，工业和信息化部、国家质量监督检验检疫总局、中国人民银行、国务院国有资产监督管理委员会、国家保密局、国家认证认可监督管理委员会联合发布《关于加强信息安全管理体系统认证安全管理的通知》（工信部联协[2010]394号），加强对国有机构信息安全管理体系统认证的监督管理。
- 中心作为主要单位参与业务连续性国际标准的转化工作，近期即将推出业务连续性管理体系认证。

三、我国信息安全认证工作进展

2、我国信息安全认证认可制度与体系——服务认证

- 2007年8月22日，国家认证认可监督管理委员会批准中国信息安全认证中心开展信息安全服务认证和培训试点工作。
- 目前，中心已推出应急处理、安全集成、风险评估、灾难备份与恢复、软件安全开发、安全运维等六项认证。
- 制定供应链安全评价规范，并在华为等国内知名企业开展试点工作。

三、我国信息安全认证工作进展

3、我国信息安全认证认可制度与体系——人员认证

(1) 网络安全人才队伍建设面临的问题

- 网络安全人才培养尚未体系化
- 网络安全人才培养尚未规范化、规模化
- 网络安全人才培养缺乏自主可控和统一监管
- 网络安全人才评价缺乏客观、统一的标准

三、我国信息安全认证工作进展

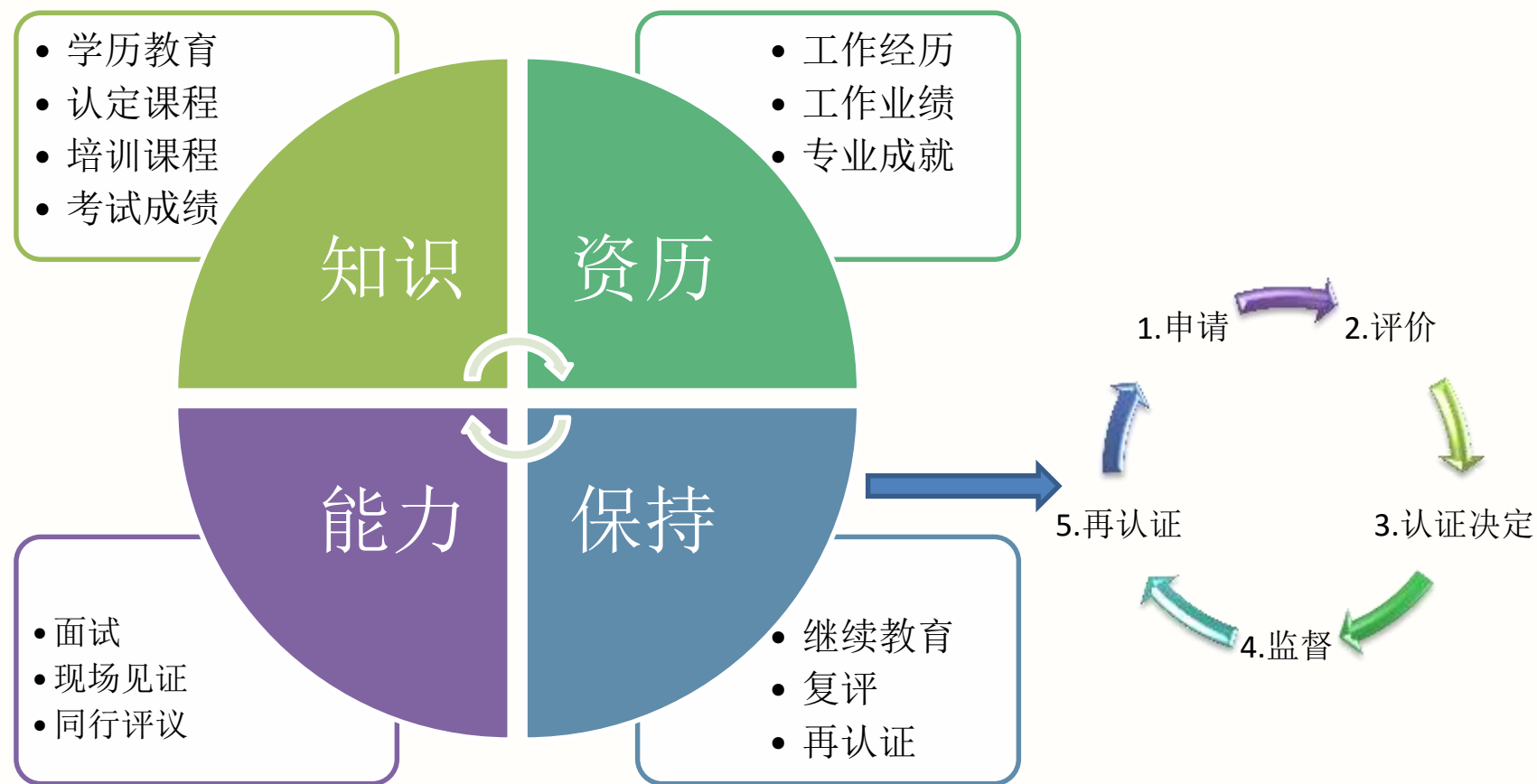
2、我国信息安全认证认可制度与体系——人员认证

- 认证对象：正式人员+预备人员；
- 专业方向：覆盖技术和管理两方面，包括安全软件、安全集成、安全管理、安全运维、政务安全、服务管理、风险管理、网络攻防、业务连续性等9个专业方向。

认证类型	级别	认证要求
专业认证	III级（专业高级）	专业课程（二级）+附加课程
	II级（专业级）	通用课程（二级）+专业课程（一级）
资格认证	I级（基础级）	基础课程+通用课程（一级）
预备认证	预备级	大专院校认定课程+基础课程+通用课程（一级）

三、我国信息安全认证工作进展

人员认证评价方法



三、我国信息安全认证工作进展

3、信息安全认证业务体系

信息安全产品认证

- 国家信息安全产品认证
- 无线局域网产品认证
- IT产品信息安全认证
- 非金融机构支付业务设施认证
- C C C 认证 (08/09/16大类)
- XBRL可交换商业报表语言认证

信息安全管理体系认证

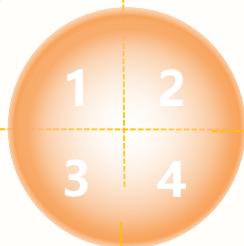
- 信息安全管理体系认证
- 信息技术服务管理体系认证
- 数据中心服务能力成熟度评价

信息安全服务资质认证

- 风险评估
- 应急处理
- 安全集成
- 灾难备份与恢复
- 软件安全开发
- 安全运维

信息安全培训和人员认证

- 审核员评审员检查员培训
- 信息安全意识公益培训
- 信息安全从业保障人员认证



即将开展：电子商务服务认证、电子招投标系统认证

三、我国信息安全认证工作进展

4、新时期对信息安全认证工作的要求

通过开展以下工作，提升我国信息安全标准、检测、认证的整体水平，助力信息安全产业发展。

（1）加快完善网络安全产品认证制度，实现“一张证书替代目前的多张证书”的目标；

（2）推动IT产品（含服务）信息安全认证工作，满足重点部门行业对重要IT产品的安全管理要求；

（3）加强对网络安全检验检测机构的技术能力和资质认定评价工作。

（4）加强对国际信息安全认证认可工作的跟踪和交流。

谢谢!